DATE:31/01/2026

EX-02

Security Models and Principles

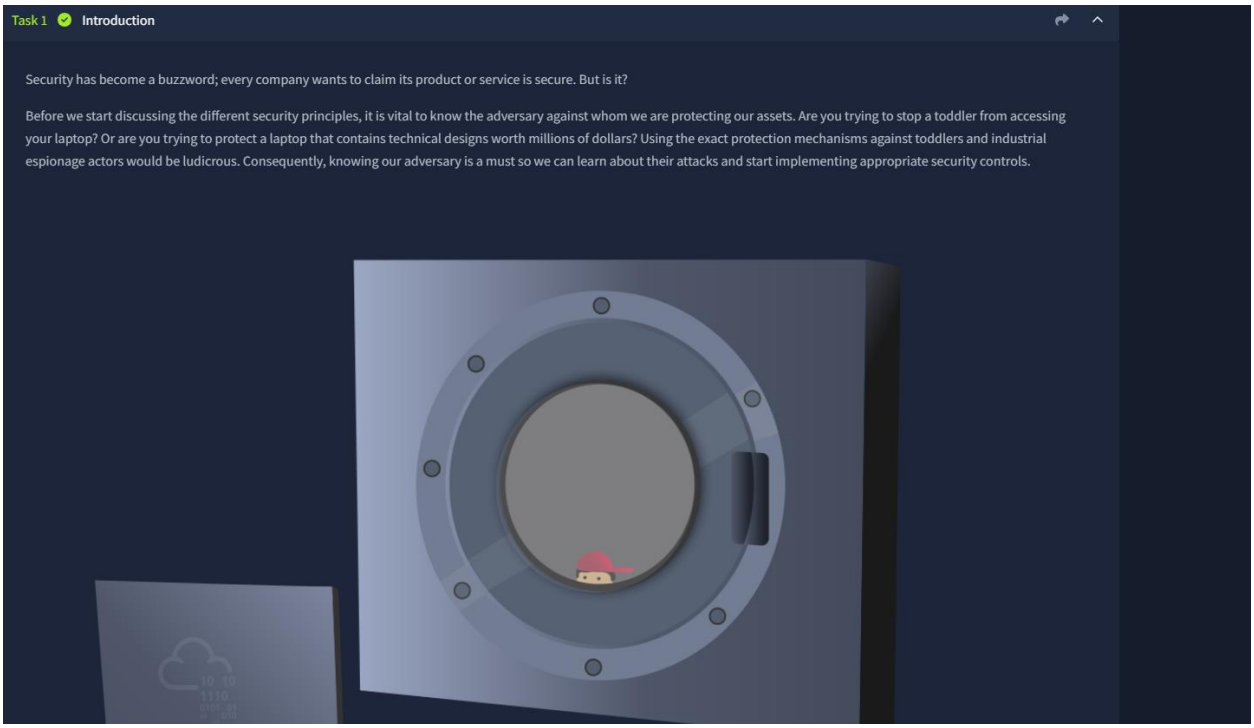
AIM:

To understand and perform the security principles such as confidentiality,Intergrity and availability Using the Tryhackme Security Principle room.

PROCEDURE:

- Study the CIA-triad
- Learn the concept of Authentication, Authorization and non- repudation.
- Go through the examples and explanations given for each principle.
- Assume the question tasks in each section.
- Verify the answer and complete the room.

TASK-1



TASK-2:

source is vital for many systems to be usable.

In online shopping, depending on your business, you might tolerate attempting to deliver a t-shirt with cash-on-delivery and learn later that the recipient never placed such an order. However, no company can tolerate shipping 1000 cars to discover that the order is fake. In the example of a shopping order, you want to confirm that the said customer indeed placed this order; that's authenticity. Moreover, you want to ensure they cannot deny placing this order; that's nonrepudiation.

As a company, if you receive a shipment order of 1000 cars, you need to ensure the authenticity of this order; moreover, the source should not be able to deny placing such an order. Without authenticity and nonrepudiation, the business cannot be conducted.

Parkerian Hexad

In 1998, Donn Parker proposed the Parkerian Hexad, a set of six security elements. They are:

1. Availability
2. Utility
3. Integrity
4. Authenticity
5. Confidentiality
6. Possession

We have already covered four of the above six elements. Let's discuss the remaining two elements:

- **Utility**: Utility focuses on the usefulness of the information. For instance, a user might have lost the decryption key to access a laptop with encrypted storage. Although the user still has the laptop with its disk(s) intact, they cannot access them. In other words, although still available, the information is in a form that is not useful, i.e., of no utility.
- **Possession**: This security element requires that we protect the information from unauthorized taking, copying, or controlling. For instance, an adversary might take a backup drive, meaning we lose possession of the information as long as they have the drive. Alternatively, the adversary might succeed in encrypting our data using ransomware; this also leads to the loss of possession of the data.

Answer the questions below

Click on "View Site" and answer the five questions. What is the flag that you obtained at the end?

THM{CIA_TRIAD} ✓ Correct Answer

TASK-3:

The security of a system is attacked through one of several means. It can be via the disclosure of secret data, alteration of data, or destruction of data.

- **Disclosure** is the opposite of confidentiality. In other words, disclosure of confidential data would be an attack on confidentiality.
- **Alteration** is the opposite of Integrity. For example, the integrity of a cheque is indispensable.
- **Destruction/Denial** is the opposite of Availability.

The opposite of the CIA Triad would be the DAD Triad: Disclosure, Alteration, and Destruction.

Consider the previous example of patient records and related systems:

- Disclosure: As in most modern countries, healthcare providers must maintain medical records' confidentiality. As a result, if an attacker succeeds in stealing some of these medical records and dumping them online to be viewed publicly, the health care provider will incur a loss due to this data disclosure attack.
- Alteration: Consider the gravity of the situation if the attacker manages to modify patient medical records. This alteration attack might lead to the wrong treatment being administered, and consequently, this alteration attack could be life-threatening.
- Destruction/Denial: Consider the case where a medical facility has gone completely paperless. If an attacker manages to make the database systems unavailable, the facility will not be able to function properly. They can go back to paper temporarily; however, the patient records won't be available. This denial attack would stall the whole facility.

Protecting against disclosure, alteration, and destruction/denial is of utter significance. This protection is equivalent to working to maintain confidentiality, integrity and availability.

Protecting confidentiality and integrity to an extreme can restrict availability, and increasing availability to an extreme can result in losing confidentiality and integrity. Good security principles implementation requires a balance between the three.

Answer the questions below

The attacker managed to gain access to customer records and dumped them online. What is this attack?

Disclosure ✓ Correct Answer

A group of attackers were able to locate both the main and the backup power supply systems and switch them off. As a result, the whole network was shut down. What is this attack?

Destruction/Denial ✓ Correct Answer

TASK-4:

Biba Model

The Biba Model aims to achieve **integrity** by specifying two main rules:

- **Simple Integrity Property** : This property is referred to as "no read down"; a higher integrity subject should not read from a lower integrity object.
- **Star Integrity Property** : This property is referred to as "no write up"; a lower integrity subject should not write to a higher integrity object.

These two properties can be summarized as "read up, write down." This rule is in contrast with the Bell-LaPadula Model, and this should not be surprising as one is concerned with confidentiality while the other is with integrity.

Biba Model suffers from various limitations. One example is that it does not handle internal threats (insider threat).

Clark-Wilson Model

The Clark-Wilson Model also aims to achieve integrity by using the following concepts:

- **Constrained Data Item (CDI)** : This refers to the data type whose integrity we want to preserve.
- **Unconstrained Data Item (UDI)** : This refers to all data types beyond CDI, such as user and system input.
- **Transformation Procedures (TPs)** : These procedures are programmed operations, such as read and write, and should maintain the integrity of CDIs.
- **Integrity Verification Procedures (IVPs)** : These procedures check and ensure the validity of CDIs.

We covered only three security models. The reader can explore many additional security models. Examples include:

- Brewer and Nash model
- Goguen-Meseguer model
- Sutherland model
- Graham-Denning model
- Harrison-Ruzzo-Ullman model

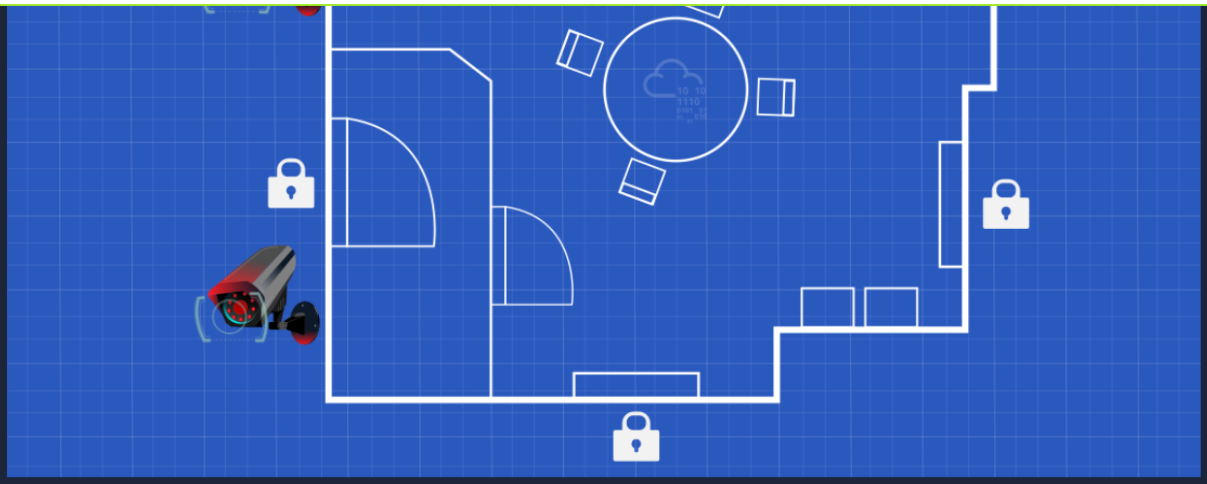
Answer the questions below

Click on "View Site" and answer the four questions. What is the flag that you obtained at the end?

THM{SECURITY_MODELS}

✓ Correct Answer

TASK-5:



Defence-in-Depth refers to creating a security system of multiple levels; hence it is also called Multi-Level Security.

Consider the following analogy: you have a locked drawer where you keep your important documents and pricey stuff. The drawer is locked; however, do you want this drawer lock to be the only thing standing between a thief and your expensive items? If we think of multi-level security, we would prefer that the drawer be locked, the relevant room be locked, the main door of the apartment be locked, the building gate be locked, and you might even want to throw in a few security cameras along the way. Although these multiple levels of security cannot stop every thief, they would block most of them and slow down the others.

Answer the questions below

Make sure you have read the above.

No answer needed

✓ Correct Answer

TASK-6:

teaches that you should provide the least amount of permissions for someone to carry out their task and nothing more. For example, if a user needs to be able to view a document, you should give them read rights without write rights.

2. **Attack Surface Minimisation**: Every system has vulnerabilities that an attacker might use to compromise a system. Some vulnerabilities are known, while others are yet to be discovered. These vulnerabilities represent risks that we should aim to minimize. For example, in one of the steps to harden a Linux system, we would disable any service we don't need.
3. **Centralized Parameter Validation**: Many threats are due to the system receiving input, especially from users. Invalid inputs can be used to exploit vulnerabilities in the system, such as denial of service and remote code execution. Therefore, parameter validation is a necessary step to ensure the correct system state. Considering the number of parameters a system handles, the validation of the parameters should be centralized within one library or system.
4. **Centralized General Security Services**: As a security principle, we should aim to centralize all security services. For example, we would create a centralized server for authentication. Of course, you might take proper measures to ensure availability and prevent creating a single point of failure.
5. **Preparing for Error and Exception Handling**: Whenever we build a system, we should take into account that errors and exceptions do and will occur. For instance, in a shopping application, a customer might try to place an order for an out-of-stock item. A database might get overloaded and stop responding to a web application. This principle teaches that the systems should be designed to fail safe; for example, if a firewall crashes, it should block all traffic instead of allowing all traffic. Moreover, we should be careful that error messages don't leak information that we consider confidential, such as dumping memory content that contains information related to other customers.

In the following questions, refer to the ISO/IEC 19249 five design principles above. Answer with a number between 1 and 5, depending on the number of the design principle.

Answer the questions below

Which principle are you applying when you turn off an insecure server that is not critical to the business?

2 — ✓ Correct Answer

Your company hired a new sales representative. Which principle are they applying when they tell you to give them access only to the company products and prices?

1 — ✓ Correct Answer

While reading the code of an ATM, you noticed a huge chunk of code to handle unexpected situations such as network disconnection and power failure. Which principle are they applying?

5 — ✓ Correct Answer

TASK-7:

Task 7 ✓ Zero Trust versus Trust but Verify

Trust is a very complex topic; in reality, we cannot function without trust. If one were to think that the laptop vendor has installed spyware on the laptop, they would most likely end up rebuilding the system. If one were to mistrust the hardware vendor, they would stop using it completely. If we think of trust on a business level, things only become more sophisticated; however, we need some guiding security principles. Two security principles that are of interest to us regarding trust:

- Trust but Verify
- Zero Trust

Trust but Verify: This principle teaches that we should always verify even when we trust an entity and its behaviour. An entity might be a user or a system. Verifying usually requires setting up proper logging mechanisms; verifying indicates going through the logs to ensure everything is normal. In reality, it is not feasible to verify everything; just think of the work it takes to review all the actions taken by a single entity, such as Internet pages browsed by a single user. This requires automated security mechanisms, such as proxy, intrusion detection, and intrusion prevention systems.

Zero Trust: This principle treats trust as a vulnerability, and consequently, it caters to insider-related threats. After considering trust as a vulnerability, zero trust tries to eliminate it. It is teaching indirectly, "never trust, always verify." In other words, every entity is considered adversarial until proven otherwise. Zero trust does not grant trust to a device based on its location or ownership. This approach contrasts with older models that would trust internal networks or enterprise-owned devices. Authentication and authorization are required before accessing any resource. As a result, if any breach occurs, the damage would be more contained if a zero trust architecture had been implemented.

Microsegmentation is one of the implementations used for Zero Trust. It refers to the design where a network segment can be as small as a single host. Moreover, communication between segments requires authentication, access control list checks, and other security requirements.

There is a limit to how much we can apply zero trust without negatively impacting a business; however, this does not mean that we should not apply it as long as it is feasible.

Answer the questions below

Make sure you have read the above.

No answer needed — ✓ Correct Answer

TASK-8:

There are three terms that we need to take note of to avoid any confusion.

- **Vulnerability**: Vulnerable means susceptible to attack or damage. In information security, a vulnerability is a weakness.
- **Threat**: A threat is a potential danger associated with this weakness or vulnerability.
- **Risk**: The risk is concerned with the likelihood of a threat actor exploiting a vulnerability and the consequent impact on the business.

Away from information systems, a showroom with doors and windows made of standard glass suffers a weakness, or *vulnerability*, due to the nature of glass. Consequently, there is a *threat* that the glass doors and windows can be broken. The showroom owners should contemplate the *risk*, i.e. the likelihood that a glass door or window gets broken and the resulting impact on the business.

Consider another example directly related to information systems. You work for a hospital that uses a particular database system to store all the medical records. One day, you are following the latest security news, and you learn that the used database system is not only vulnerable but also a proof-of-concept working exploit code has been released; the released exploit code indicates that the threat is real. With this knowledge, you must consider the resulting risk and decide the next steps.

We will cover threats and risks in detail in a separate room.

Answer the questions below

Make sure you have read the above.

No answer needed

✓ Correct Answer

TASK-9:

Task 9 Conclusion

This room covered various principles and concepts related to security. By now, you should be very familiar with CIA and DAD and other terms such as authenticity, repudiation, vulnerability, threat, and risk. We visited three security models and the ISO/IEC 19249. We have covered different security principles such as defence in depth, trust but verify, and zero trust.

Finally, the Shared Responsibility Model is worth mentioning, especially with the increased reliance on cloud services. Various aspects are required to ensure proper security. They include hardware, network infrastructure, operating systems, applications, etc. However, customers using cloud services have different access levels depending on the cloud services they use. For example, an Infrastructure as a Service (IaaS) user has complete control (and responsibility) over the operating system.

On the other hand, a Software as a Service (SaaS) user has no direct access to the underlying operating system. Consequently, achieving security in a cloud environment necessitates both the cloud service provider and the user to do their parts. The Shared Responsibility Model is a cloud security framework to ensure that each party is aware of its responsibility.

Having finished the Security Principles room, you may proceed to the Intro to Cryptography room.

Answer the questions below

Make sure you have taken notes of all the key terms and acronyms we covered in this room.

No answer needed

✓ Correct Answer

RESULT:

Successfully Learned the Security Principles.